

9



Módulo 09

Infraestrutura de Chaves Públicas e Blockchain

Aula 03

Gerenciamento de Infraestrutura de Chaves Públicas (PKI)

Introdução —

Nesta aula, você conhecerá os seguintes assuntos:

- Gerenciamento do ciclo de vida dos Certificados e Chaves;
- Recuperação e custódia de chaves com o uso de hardware especializado;
- Lista de Certificados Revogados (LCR) e protocolo OCSP;
- Pinning de certificados; e
- Uso prático de OpenSSL.

Aula 03

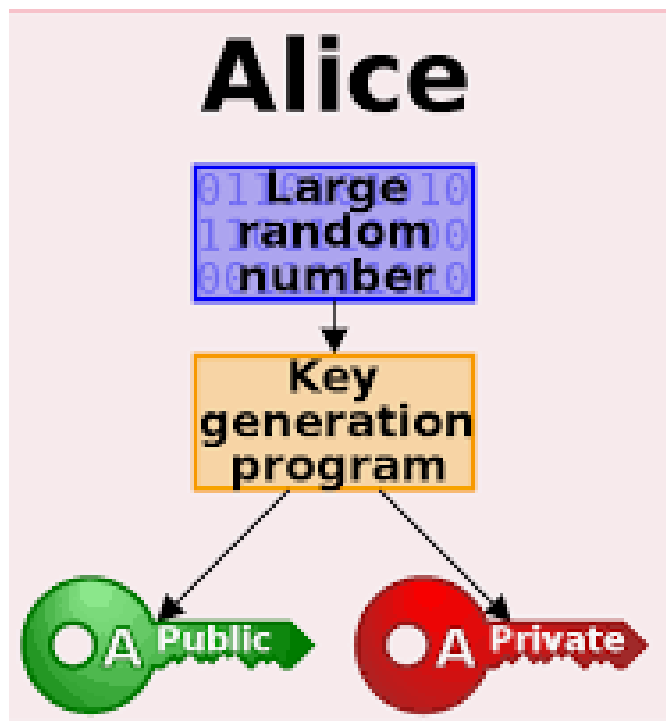
Infraestrutura de Chaves Públicas e Blockchain

Gerenciamento de Chaves

GERENCIAMENTO DE CHAVES

- Abrange a administração e o controle das chaves de criptografia utilizadas em certificados digitais.
- Garante os três princípios fundamentais da segurança da informação:
 - Confidencialidade;
 - Integridade;
 - Autenticidade.





Fonte: wikipedia, 2024.

Disponível em:

https://pt.wikipedia.org/wiki/Criptografia_de_chave_p%C3%ABblica

Acesso em: 20 mar. 2024

CICLO DE VIDA DAS CHAVES

- Etapas do ciclo de vida:
 - Confidencialidade;
 - Solicitação e Emissão de Certificados;
 - Armazenamento e Proteção;
 - Renovação e Atualização;
 - Revogação;
 - Destruição.



Fonte: servicenow, 2024.

Disponível em:

<https://www.servicenow.com/br/products/it-operations-management/what-is-certificate-management.html>

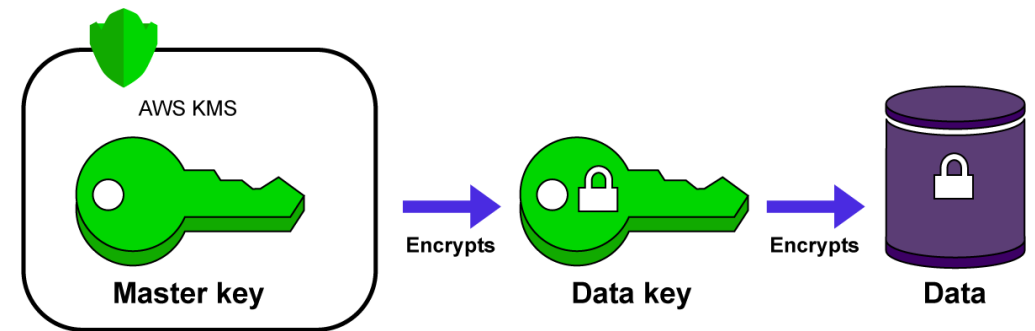
Acesso em: 20 mar. 2024

TIPOS DE GERENCIAMENTO DE CHAVE

- Gerenciamento de Chaves Centralizado:
 - Armazenamento e gerenciamento a partir de um ponto central;
 - Servidor de chaves dedicado;
 - Executado pelas Autoridades Certificadoras (ACs);
 - Controle mais rigoroso e padronizado.

TIPOS DE GERENCIAMENTO DE CHAVE

- Gerenciamento de Chaves Descentralizado:
 - Armazenamento e gerenciamento distribuídos;
 - Cada entidade gera suas próprias chaves e certificados;
 - Maior autonomia e flexibilidade;
 - Dificuldades de coordenação e padronização.



Fonte: smartsheet, 2024.

Disponível em: <<https://help.smartsheet.com/pt/articles/2482311-customer-managed-encryption-keys>>.

Acesso em: 20 mar. 2024.

VULNERABILIDADES NO GERENCIAMENTO DE CERTIFICADOS

- O Gerenciamento inadequado acarreta em vulnerabilidades como:
 - Exposição de Chaves Privadas;
 - Certificados Inválidos ou Comprometidos;
 - Falta de Revogação de Certificados.



Há um problema no certificado de segurança do site.

O certificado de segurança apresentado pelo site foi emitido para outro endereço.
O certificado de segurança apresentado pelo site não foi emitido por uma autoridade de certificação confiável.

Problemas de certificado de segurança podem indicar uma tentativa de enganá-lo ou de interceptar algum dado enviado ao servidor.

Recomendamos fechar a página da Web e não continuar no site.

✓ Clique aqui para fechar esta página da Web.



✗ Continuar neste site (não recomendado).

ⓘ Mais informações

VULNERABILIDADES NO GERENCIAMENTO DE CERTIFICADOS

- O Gerenciamento inadequado acarreta em vulnerabilidades como:
 - Falha na Renovação de Certificados;
 - Uso de Algoritmos e Parâmetros Obsoletos;
 - Falta de Monitoramento e Auditoria.



CONTROLE DE ACESSO A CHAVES

- O mecanismo empregado é denominado controle M de N, mais utilizado em ambientes de alto risco.
- “M” é o número mínimo de entidades para desbloquear as chaves privadas;
- “N” é o número total de entidades ou partes envolvidas.
- Por exemplo, em um controle 2 de 3 duas das três entidades autorizadas participam para desbloquear as chaves privadas.



CUSTÓDIA DE CHAVES (*KEY ESCROW*)

- Consiste em um mecanismo confiável para armazenar uma cópia de segurança das chaves privadas;
- O objetivo é garantir a recuperação das chaves originais em caso de perda, corrupção ou comprometimento;
- A terceira parte confiável pode ser uma AC ou uma agência governamental.



Aula 03

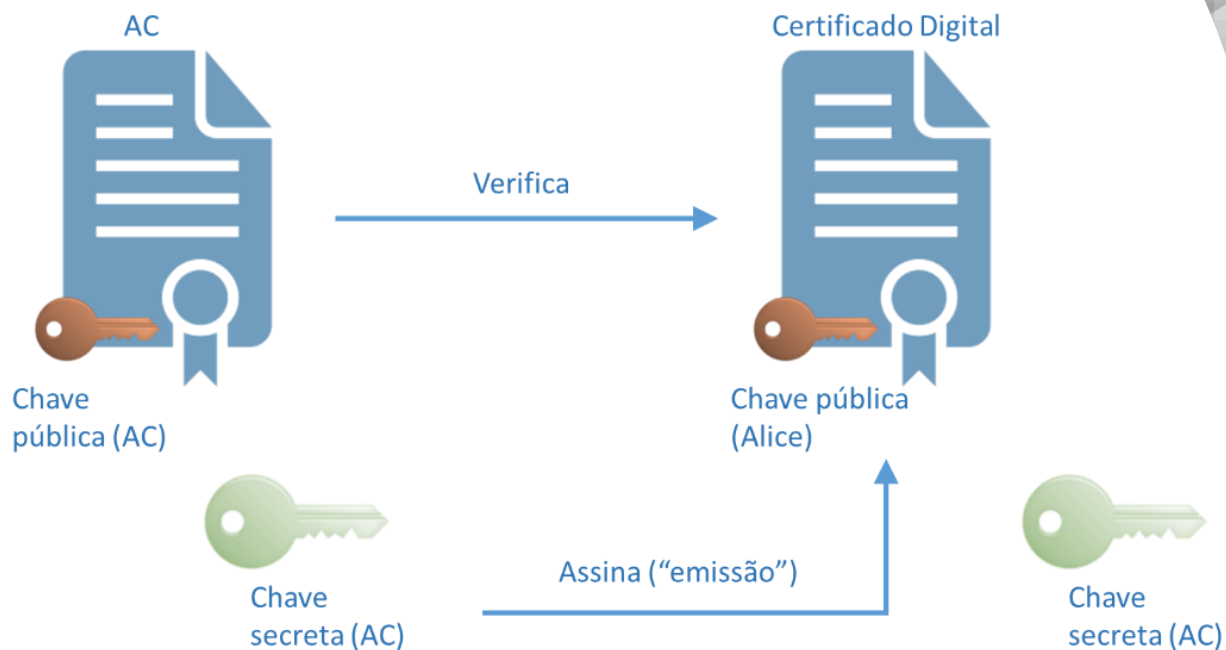
Infraestrutura de Chaves Públicas e Blockchain

Gerenciamento de Certificados —

GERENCIAMENTO DE CERTIFICADOS

- É um conjunto de práticas e processos utilizados para administrar certificados digitais em uma PKI.
- Gerencia todo o ciclo de vida dos certificados e seu armazenamento seguro;
- O objetivo é garantir autenticidade, integridade e confidencialidade na troca de informações.





Fonte: welivesecurity, 2017.
Disponível em:
<https://www.welivesecurity.com/br/2017/04/28/certificados-dos-digitais-e-infraestrutura-de-chaves-publicas/>
Acesso em: 20 mar. 2024

GERAÇÃO DE CERTIFICADOS

— Etapas envolvidas:

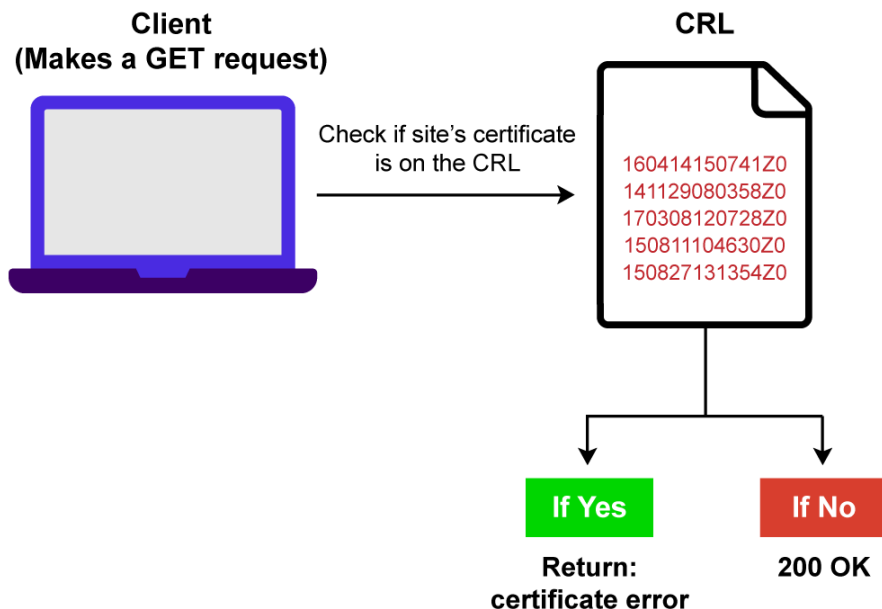
- Solicitação de Certificado;
- Criação do Par de Chaves;
- Preenchimento dos Dados do Certificado;
- Assinatura Digital;
- Emissão do Certificado.



REVOGAÇÃO DE CERTIFICADOS E LISTA DE CERTIFICADOS REVOGADOS (CRL)

- A revogação de certificados digitais ocorre quando:
 - Um certificado está comprometido; ou
 - Ou é suspeito de ter sido comprometido;
 - Possui informações incorretas;
 - Ou ainda, o titular do certificado deixa de ser autorizado a utilizá-lo.





Fonte: test.fikaki, 2019.

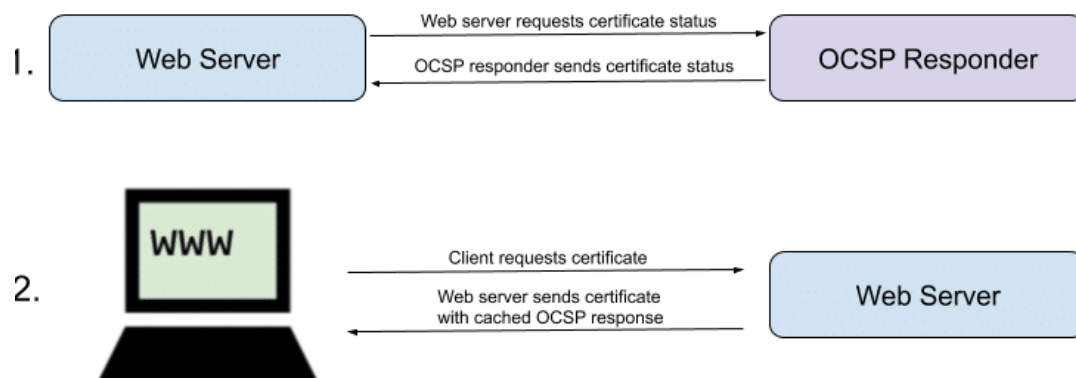
Disponível em: <<https://test.fikaki.com/certificate-revocation-list-crl/>>.

Acesso em: 20 mar. 2024.

REVOGAÇÃO DE CERTIFICADOS E LISTA DE CERTIFICADOS REVOGADOS (CRL)

Passos para a Revogação de certificados:

- Identificação da necessidade de revogação;
- Publicação da Lista de Certificados Revogados (CRL);
- Verificação da Revogação.



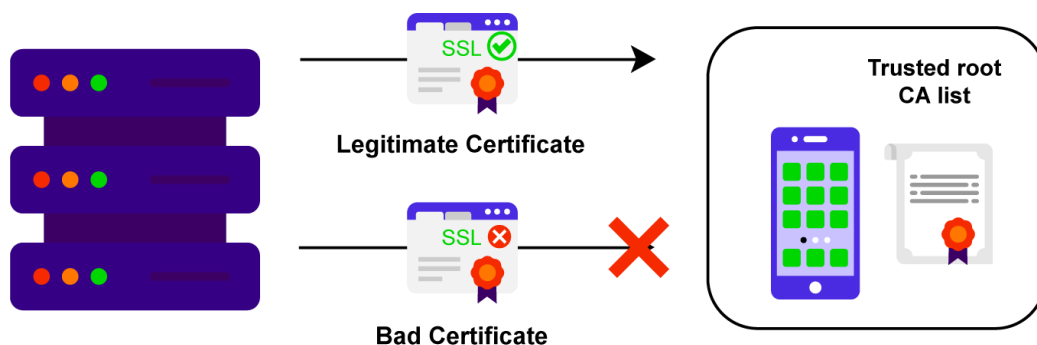
Fonte: ssl, 2020.

Disponível em: <<https://www.ssl.com/faqs/faq-digital-certificate-revocation/>>.

Acesso em: 20 mar. 2024.

ONLINE CERTIFICATE STATUS PROTOCOL (OCSP)

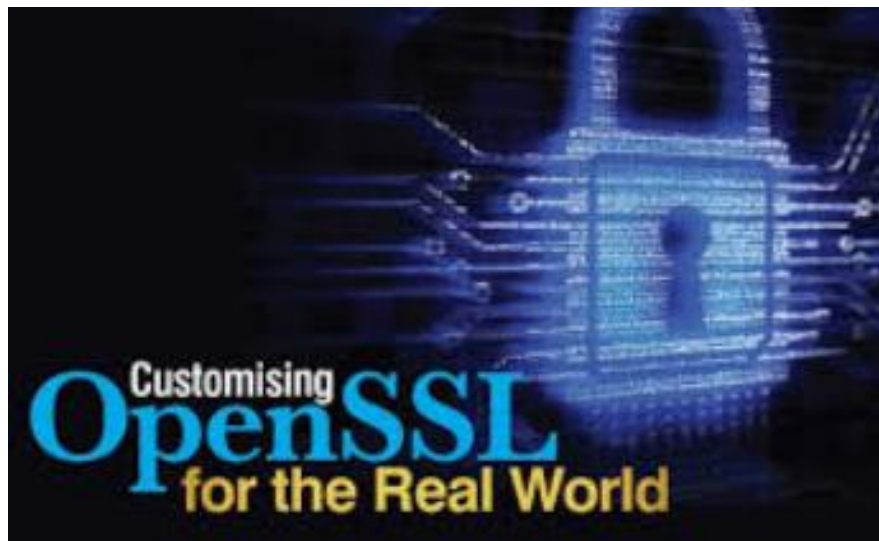
- Protocolo utilizado na consulta online do status de revogação dos certificados.
- Passos para a verificação OCSP online:
 - Solicitação OCSP;
 - Resposta OCSP;
 - Resposta OCSP ao Solicitante;
 - Validação do Certificado.



Fonte: cybertrends, 2021.
Disponível em: <<https://cybertrends-indusface.medium.com/what-is-ssl-pinning-a-quick-walk-through-d5f0d6dc0889>>.
Acesso em: 20 mar. 2024

FIXAÇÃO DE CERTIFICADO (CERTIFICATE PINNING)

- Visa garantir a autenticidade e a integridade dos certificados digitais durante a comunicação.
- Etapas do *pinning*:
 - Seleção de Certificados;
 - Armazenamento de Informações de Identificação;
 - Verificação de Certificados;
 - Comparação e Validação.



Fonte: [opensourceforu](https://www.ietf.org/rfc/rfc2818.txt), 2015.

Disponível em:

<https://www.ietf.org/rfc/rfc2818.txt>

Acesso em: 20 mar. 2024.

OpenSSL

- É uma biblioteca de código aberto utilizada para implementação de criptografia.
- Auxilia no gerenciamento de certificados em uma PKI.
- Funcionalidades oferecidas:
 - Geração de chaves;
 - Criação e assinatura de certificados.

OpenSSL

Cryptography and SSL/TLS Toolkit

Fonte: blacktdn, 2015.

Disponível em: <<https://www.blacktdn.com.br/2023/07/blacktdn-openssl-usando-https-em.html>>.

Acesso em: 20 mar. 2024

OpenSSL

- Criação e verificação de assinaturas digitais;
- Verificação de Certificados;
- Gerenciamento de CRLs;
- Implementação de OCSP Responders.

9



Você chegou ao final da Aula 03
**Gerenciamento de
Chaves e Certificado**